

 GOBERNACIÓN DE ANTIOQUIA República de Colombia	PROPUESTA TÉCNICA Y FINANCIERA DE DESARROLLO DE SOFTWARE	Código: FO-M7-P8-021
		Versión: 01
		Fecha de aprobación: 14/04/2026

PROPUESTA TÉCNICA DE DESARROLLO DE SOFTWARE

Este documento presenta una visión general de la solución tecnológica propuesta para el proyecto, detallando los objetivos, tecnologías y metodologías que se emplearán para asegurar el cumplimiento del alcance y la calidad esperada. Se abordan aspectos clave como la metodología de desarrollo seleccionada, la gestión de tareas, y los entregables planificados, ofreciendo una guía clara para el desarrollo y la implementación exitosa del proyecto.

Propuesta realizada por el contratista

Sebastián Guzmán y Alejandro López
sguzmand@gmail.com

Contenido

1. Introducción a la Solución	2
2. Detalles Técnicos	2
2.1 Metodología de Desarrollo.....	2
2.2 Stack Tecnológico	2
3. Arquitectura General.....	4
3.1 Diagrama de Arquitectura	4
3.2 Requisitos de Despliegue	4
4. Soporte y Mantenimiento	5
4.1 Periodo de Garantía	6
4.2 Acuerdo de Nivel de Servicio (SLA)	6
4.3 Mantenimiento Evolutivo (Opcional)	6
5. Cronograma de Ejecución	6
6. Propuesta Financiera del Proyecto.....	7
6.1 Estimación de costos del desarrollo	7
6.2 Costos de infraestructura (si aplica)	8
6.3 Costos de soporte y mantenimiento	8
6.4 Forma de pago (si aplica)	8
7. Diccionario de Definiciones y Acrónimos.....	8
8. Compromisos.....	8
9. Control de Ajustes	9
10. Aprobación y Firmas	10

1. Introducción a la Solución

El proyecto Antioquia Natural de la Secretaría de Ambiente, se ejecuta mediante contrato de prestación de servicios por 18 meses (ejecución, desarrollo y mantenimiento). Este documento, junto con el Levantamiento de Requisitos de Software y el Documento Integral de Desarrollo, conforma el paquete técnico que se somete a la aprobación de TI Gobernación para dar inicio a la ejecución sobre la infraestructura institucional. La ejecución sobre dicha infraestructura todavía no ha podido comenzar en tanto TI Gobernación provee el servidor y demás elementos solicitados.

Este documento actualiza y complementa la Propuesta Técnica inicial de Antioquia Natural (2026-06-24) con 3 ajustes puntuales, incorporando la retroalimentación de la revisión técnica de TI Gobernación. El stack base (Node.js, MongoDB, arquitectura modular) se mantiene sin cambios respecto de esa propuesta inicial, que no recibió objeciones técnicas en la primera revisión. Los 3 ajustes refuerzan específicamente seguridad y rendimiento, áreas donde la propuesta inicial quedó corta.

Los 3 ajustes son: (1) autenticación con Microsoft Entra ID en reemplazo de un sistema propio, (2) caché con Redis para las consultas del panel de administración contra MongoDB, y (3) análisis estático de seguridad (SAST) integrado al pipeline de CI/CD.

Nota de alcance: la versión anterior de esta propuesta incluía además un ajuste de observabilidad (monitoreo con Grafana) y uno de política de backup de MongoDB. Ambos se retiraron por instrucción de TI Gobernación: el monitoreo con Grafana no es necesario, y los respaldos de base de datos ya están cubiertos por el protocolo propio de la Gobernación. Detalle en el numeral 9 (Control de Ajustes).

2. Detalles Técnicos

2.1 Metodología de Desarrollo

Metodología ágil adaptada al equipo de desarrollo: iteraciones cortas con entrega continua, sin ceremonias formales de Scrum dado el alcance del desarrollo. Fases del ciclo: Análisis → Diseño → Desarrollo → Pruebas (QA) → Despliegue, repetidas por módulo/ajuste.

- Gestión de tareas: seguimiento vía GitHub (issues y commits referenciados), no se usa una herramienta de gestión de proyecto separada dado el tamaño del desarrollo. Una vez TI Gobernación active el proyecto institucional en Azure DevOps, los Work Items y Boards de Azure DevOps pasarán a ser la herramienta oficial de seguimiento.

- Control de versiones: GitFlow (main = producción estable, develop = integración, feature/nombre = desarrollos nuevos), con Conventional Commits (feat:, fix:, docs:).
- Entregables: incrementales, por ajuste/módulo completado, para revisión y retroalimentación de TI Gobernación.

2.2 Stack Tecnológico

A continuación, se describen las herramientas y lenguajes seleccionados por su estabilidad, escalabilidad y soporte:

Capa	Tecnología / Herramienta	Justificación Técnica	Estado
Frontend	HTML5 + CSS3 + JavaScript Vanilla	Sin dependencias de framework; app ligera, mobile-first, sin necesidad de SPA compleja	Implementado
Backend	Node.js 22 LTS + Express 4	Ya validado en la propuesta inicial; estabilidad y ecosistema maduro	Implementado
Base de Datos	MongoDB Atlas 7.x	Ya validado; esquema flexible adecuado para catálogos y fotografías con metadatos variables. Respaldo bajo el protocolo propio de TI Gobernación	Implementado
Autenticación (AJUSTE 1)	Microsoft Entra ID — OAuth 2.0 + OIDC (Authorization Code Flow + PKCE), @azure/msal-node + passport-azure-ad	Elimina contraseñas propias en la app; hereda MFA y revocación automática del tenant institucional	Pendiente de insumo TI (Client ID / Tenant ID)
Caché (AJUSTE 2)	Redis 7 + ioredis	Lecturas del panel de administración (meses, fotos y estadísticas de JPL/Guarda Cuencas) servidas desde memoria en vez de repetir la consulta a MongoDB en cada carga del panel	Implementado
SAST (AJUSTE 3)	ESLint-security + Semgrep (p/nodejs, p/owasp-top-ten) en pipeline Azure DevOps	Verifica OWASP Top 10 de forma automática y reproducible en cada push, no solo en revisión manual	Implementado
Repositorio	Git — GitHub (desarrollo), con espejo a Azure Repos institucional una vez TI active el proyecto (ver Estado de Completitud)	Control de versiones	Parcial — GitHub implementado; espejo a Azure Repos pendiente de activación por TI

3. Arquitectura General

3.1 Diagrama de Arquitectura

Arquitectura monolítica modular (mantenida de la propuesta inicial), con los 3 ajustes integrados en los puntos donde aportan valor: autenticación, capa de caché y pipeline de CI/CD.

- Patrón de diseño: separación rutas → servicios → modelos (routes/admin.js delega a services/, que usan models/ vía Mongoose).
- Comunicación: API RESTful bajo HTTPS.
- Seguridad: autenticación mediante OAuth 2.0/OIDC mediante Entra ID (AJUSTE 1); cifrado en tránsito (TLS 1.2+) y en reposo (por defecto en MongoDB Atlas).

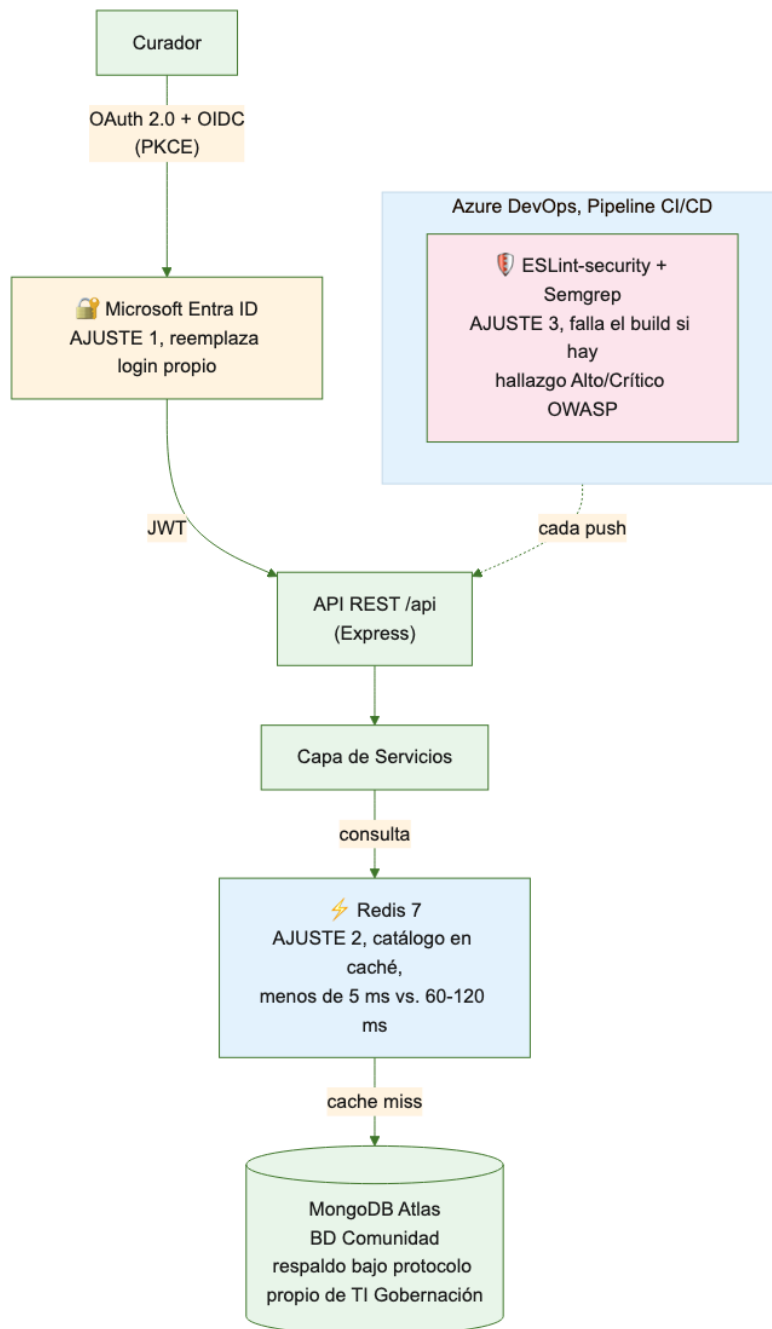


Figura 1. Arquitectura general con los 3 ajustes técnicos integrados.

3.2 Requisitos de Despliegue

Para la correcta ejecución del sistema en producción, se requiere:

- Servidor de Aplicaciones: Ubuntu Server 24.04 LTS, 4 vCPU, 16 GB RAM.

- Almacenamiento: 2 TB (fotografías del catálogo y de los programas comunitarios).
- Base de Datos: MongoDB Atlas (cluster ya provisionado, plan M0).
- Redis 7 en modo standalone, en el mismo servidor Ubuntu — sin costo de infraestructura adicional (AJUSTE 2).
- Dominio institucional y certificado SSL (Let's Encrypt / Certbot) — requeridos para acceso seguro.

4. Soporte y Mantenimiento

4.1 Periodo de Garantía

El proyecto se ejecuta mediante contrato de prestación de servicios por 18 meses entre el contratista y la Secretaría de Ambiente, que cubre ejecución, desarrollo y mantenimiento del desarrollo durante toda su vigencia. No aplica un periodo de garantía posterior a una entrega puntual, como en la venta de un producto: el soporte correctivo está incluido de forma continua mientras el contrato esté vigente.

- Cobertura: corrección de errores (bugs) imputables al código desarrollado, durante toda la vigencia del contrato.
- Exclusiones: fallos ocasionados por infraestructura de terceros o mal uso del sistema.

4.2 Acuerdo de Nivel de Servicio (SLA)

El cumplimiento de estos tiempos se verifica con los logs estructurados de Winston y el endpoint /api/health ya implementados, y con el protocolo de monitoreo propio de TI Gobernación sobre la infraestructura institucional:

Prioridad	Descripción	Tiempo de Respuesta	Tiempo de Resolución (Est.)
Crítica	Sistema caído o función principal bloqueada.	< 4 horas	< 24 horas
Alta	Funcionalidad importante con fallos, existe workaround.	< 24 horas	2 - 3 días hábiles
Media/Baja	Errores cosméticos o mejoras menores.	< 48 horas	A convenir

4.3 Mantenimiento Evolutivo (Opcional)

Durante los 18 meses del contrato, el mantenimiento evolutivo incluido en la ejecución contratada se limita a ajustes menores dentro del alcance ya definido en el Levantamiento de Requisitos de Software y en los Ajustes 1 a 3 de este documento (por ejemplo: corrección de comportamiento, ajustes de textos o de flujo dentro de un módulo ya contemplado). No incluye módulos, funcionalidades o integraciones nuevas que no estén contempladas en dicho alcance: cualquier ampliación de alcance, ocurra

en el mes 1 o en el mes 18 del contrato, requiere una ampliación contractual aparte, a convenir con la Secretaría de Ambiente. Al finalizar el contrato, cualquier soporte o desarrollo adicional se definirá mediante una nueva contratación.

5. Cronograma de Ejecución

Secuencia de implementación de los 3 ajustes. Las duraciones son estimadas y están sujetas a la aprobación oportuna de cada entregable por parte de TI Gobernación — en particular, el AJUSTE 1 depende de que la Gobernación registre la aplicación en su tenant de Entra ID (Client ID y Tenant ID) antes de poder iniciar.

Fase / Módulo	Actividad Principal	Duración Estimada	Dependencia	Entregable
Fase 0	Registro de la app en el tenant de Entra ID de la Gobernación	1 semana	Client ID y Tenant ID provistos por TI	App registrada, redirect_uri configurados (QA y Prod)
Ajuste 1	Migración de autenticación a Microsoft Entra ID	1-2 semanas	Fase 0 completa	Login del panel admin vía Entra ID en QA
Ajuste 2	Integración de Redis como caché	1-2 semanas	Ninguna	Panel admin (JPL/GC) sirviendo meses, fotos y estadísticas desde caché
Ajuste 3	SAST en pipeline de Azure DevOps	1-2 semanas	Activación del proyecto Azure DevOps por TI	Pipeline con ESLint-security + Semgrep bloqueante

6. Propuesta Financiera del Proyecto

Las cifras de este capítulo se definen directamente con la Secretaría de Ambiente, en su calidad de área funcional y ordenadora del gasto del proyecto, conforme al procedimiento presupuestal interno de la Gobernación. La estructura de tablas exigida por la plantilla está lista a continuación; los valores ya acordados se incorporan formalmente antes de la versión final de este documento

6.1 Estimación de costos del desarrollo

Concepto	Descripción	Unidad	Cantidad	Valor Unitario	Valor Total
Análisis y diseño	Levantamiento y estructuración de la solución	Global	1	Incluido en el contrato de servicios vigente	Incluido en el contrato de servicios vigente
Desarrollo	Construcción de funcionalidades	Global	1	Incluido en el contrato de servicios vigente	Incluido en el contrato de servicios vigente
Pruebas	Validación funcional y técnica	Global	1	Incluido en el contrato de servicios vigente	Incluido en el contrato de servicios vigente
Despliegue	Implementación en producción	Global	1	Incluido en el contrato de servicios vigente	Incluido en el contrato de servicios vigente
Capacitación	Transferencia de conocimiento	Global	1	Incluido en el contrato de servicios vigente	Incluido en el contrato de servicios vigente

6.2 Costos de infraestructura (si aplica)

Concepto	Tipo (Nube / On-Premise)	Descripción	Periodicidad	Valor
Redis 7	On-Premise (mismo servidor Ubuntu)	Sin costo adicional — corre junto al backend	N/A	\$0

El respaldo de la base de datos MongoDB no se incluye como costo de este proyecto: se rige por el protocolo de respaldos propio de TI Gobernación.

6.3 Costos de soporte y mantenimiento

Concepto	Descripción	Periodicidad	Valor
Soporte correctivo	Atención de incidentes (cubierto por 18 meses durante la ejecución del contrato)	Incluido	\$0
Soporte evolutivo	Nuevas funcionalidades tras la garantía	Por hora / mensual	Pendiente

6.4 Forma de pago (si aplica)

Mensual

7. Diccionario de Definiciones y Acrónimos

Término	Definición
SAST	Static Application Security Testing — análisis estático de seguridad sobre el código fuente, sin ejecutarlo.

Término	Definición
MFA	Multi-Factor Authentication — autenticación con más de un factor (ej. contraseña + app de autenticación).
OIDC	OpenID Connect — capa de identidad construida sobre OAuth 2.0, usada por Entra ID.
OAuth 2.0	Estándar abierto de autorización delegada.
PKCE	Proof Key for Code Exchange — extensión de OAuth 2.0 que protege el flujo de autorización contra interceptación.
JWT	JSON Web Token — formato estándar de token firmado usado para transmitir la sesión autenticada.
MSAL	Microsoft Authentication Library — librería oficial de Microsoft para integrar Entra ID.
TTL	Time To Live — tiempo que un dato permanece válido en caché antes de expirar.
SLA	Service Level Agreement — acuerdo de nivel de servicio (tiempos de respuesta y resolución).
CVE	Common Vulnerabilities and Exposures — identificador estándar de vulnerabilidades conocidas.
OWASP	Open Web Application Security Project — organización que publica el listado "Top 10" de riesgos de seguridad web.

8. Compromisos

- Propiedad Intelectual: los derechos patrimoniales sobre el software desarrollado, incluidos los 3 ajustes de este documento, son de la Gobernación de Antioquia, en cumplimiento de la sección 1.4 de la Guía de Arquitectura y Buenas Prácticas de Desarrollo de la entidad. El contratista conserva sus derechos morales como autor del desarrollo.
- Confidencialidad: toda la información compartida durante el desarrollo será tratada bajo estricta confidencialidad.
- Cumplimiento normativo — Ley 1581 (Habeas Data): el AJUSTE 1 (Entra ID) cambia el modelo de custodia de identidades de los curadores — la aplicación deja de almacenar contraseñas y delega la autenticación al tenant institucional de la Gobernación. Esto refuerza, no debilita, el cumplimiento de la Ley 1581: menos datos sensibles bajo responsabilidad directa del contratista, y trazabilidad de accesos gestionada centralmente por TI.
- El desarrollo se apegará a los lineamientos de seguridad y buenas prácticas de codificación de la Guía de Arquitectura y Buenas Prácticas de Desarrollo de la Gobernación de Antioquia.

9. Control de Ajustes

Registro de cambios realizados a esta propuesta técnica.

Versión	Fecha	Descripción del Cambio	Responsable
1.0	2026-06-24	Propuesta Técnica inicial: stack Node.js/MongoDB, arquitectura modular, alcance funcional de los módulos Biodiversidad, Agua y Comunidad.	Sebastián Guzmán Díaz
2.0	2026-06-24	Propuesta de Ajustes Técnicos: 5 cambios (Entra ID, Redis, Observabilidad, SAST, Backup) en respuesta a observaciones de TI Gobernación sobre seguridad, monitoreo y continuidad de datos.	Sebastián Guzmán Díaz
2.1	2026-07-28	Reestructuración documental conforme a la plantilla institucional FO-M7-P8-021: portada, tabla de contenido, propuesta financiera, control de ajustes, diccionario de acrónimos, compromisos y bloque de firmas.	Sebastián Guzmán Díaz
2.2	2026-07-29	Por instrucción de TI Gobernación (Miguel Pérez): se retira el Ajuste de Observabilidad (monitoreo con Grafana, no necesario) y el Ajuste de Backup (la Gobernación tiene su propio protocolo de respaldos de MongoDB). Quedan 3 ajustes: Entra ID, Redis y SAST, reenumerados en consecuencia.	Sebastián Guzmán Díaz

10. Aprobación y Firmas

Al firmar este documento, las partes aceptan el alcance técnico, la metodología y los tiempos propuestos para los 3 ajustes descritos.

Por el Cliente (Gobernación de Antioquia):

Nombre: _____

Cargo: _____

Fecha: _____

Por el Proveedor de Desarrollo:

Nombre: Sebastián Guzmán Díaz

Cargo: Contratista

Fecha: _____